

Security+ 3.3 · Data Types & Classifications

Mestre CyberSec · Lesson 3.3 — Data Types & Classifications (5:54) · [Assistir Vídeo no YouTube](#) · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Classificar o dado: PUBLIC (nada perde); INTERNAL (apenas dentro); CONFIDENTIAL (estratégia, PII — fuga = dano grave); RESTRICTED (trade secret — fuga=catastrófico). A classificação DETERMINA o controle. PHI=dado de saúde; PCI-DSS=cartão.

💡 Key Exam Highlights & Critical Concepts

- Classificação determina QUAL proteção cada dado recebe
- PHI = saúde; PCI-DSS = cartão; PII = dados pessoais

🎯 Exam Tips & Typical CompTIA Scenarios

- 'least restrictive classification'=public; 'most restrictive'=restricted

Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 3.3 — Data Types & Classifications)

Why is this advanced coverage required for SY0-701? Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Public Data (N/A)

Information approved for release to anyone with no expectation of confidentiality; disclosure causes no damage.

 **Exam Trap:** Gatilho: 'least restrictive classification' = Public. Se puder ser compartilhado livremente, é Public.

• Internal Data (N/A)

Information intended only for use within the organization; unauthorized disclosure may cause limited operational or reputational harm.

 **Exam Trap:** Gatilho: uso apenas dentro da empresa, nem público nem altamente sensível. Não confundir com Public.

• Confidential Data (N/A)

Sensitive information such as business strategy or PII; unauthorized disclosure can cause serious damage to the organization or individuals.

 **Exam Trap:** Gatilho: PII, estratégia, planos internos = Confidential. Fuga gera dano grave.

• Restricted Data (N/A)

Most sensitive classification, including trade secrets; unauthorized disclosure causes catastrophic damage and requires the strictest controls.

 **Exam Trap:** Gatilho: 'most restrictive classification' = Restricted. Trade secret/fuga catastrófica = Restricted.

• Personally Identifiable Information (PII)

Data that can identify a specific individual, such as name, SSN, or biometrics; often classified as Confidential and protected by privacy laws.

 **Exam Trap:** Gatilho: PII = dados pessoais; se vazar, geralmente é Confidential com dano grave.

• Protected Health Information (PHI)

Health information that identifies an individual and is protected under regulations such as HIPAA; requires strict privacy and security controls.

 **Exam Trap:** Gatilho: PHI = dado de saúde. Se a questão citar HIPAA ou prontuário, pense PHI.

• Payment Card Industry Data Security Standard (PCI-DSS)

Security standard for organizations that store, process, or transmit cardholder data; noncompliance can lead to fines and loss of payment processing.

 **Exam Trap:** Gatilho: PCI-DSS = cartão/cardholder data. Não é uma classificação, é um padrão de compliance.

• Data Classification (N/A)

Process of labeling data based on sensitivity and value so that appropriate security controls and handling procedures are applied.

 **Exam Trap:** Gatilho: a classificação DETERMINA o controle. Primeiro classifique, depois aplique proteção proporcional.

Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A hospital stores patient names, diagnoses, medication histories, and insurance identifiers in a clinical records system. The security team must document the regulated data type represented by this dataset. Which data type is it?

- A) Public data
- B) Personally identifiable information (PII)
- C) Protected health information (PHI)
- D) Payment card data

QUESTION 2 · EXAM SCENARIO

An HR system contains employee Social Security numbers, home addresses, dates of birth, and emergency contact details. Which data type is represented?

- A) Public data
- B) Personally identifiable information (PII)
- C) Protected health information (PHI)
- D) Payment card data

QUESTION 3 · EXAM SCENARIO

A retail payment application processes customer primary account numbers, expiration dates, and service codes during checkout. Which regulated data type applies to this information?

- A) Personally identifiable information (PII)
- B) Protected health information (PHI)
- C) Payment Card Industry Data Security Standard (PCI-DSS) data
- D) Public data

QUESTION 4 · EXAM SCENARIO

A company posts its annual sustainability report on an externally accessible website so that anyone can download it without authentication. Under a four-level policy of Public, Internal, Confidential, and Restricted, how should this report be classified?

- A) Public
- B) Internal
- C) Confidential
- D) Restricted

QUESTION 5 · EXAM SCENARIO

A directory of employee names and work extension numbers is accessible only from the corporate network and is not shared with customers, vendors, or the public. How should this directory be classified under a four-level policy of Public, Internal, Confidential, and Restricted?

- A) Public
- B) Internal
- C) Confidential
- D) Restricted

QUESTION 6 · EXAM SCENARIO

A marketing database contains customer names, email addresses, order histories, and loyalty account numbers. Unauthorized disclosure would cause serious reputational and regulatory harm to the company. Under a four-level policy of Public, Internal, Confidential, and Restricted, how should this database be classified?

- A) Public
- B) Internal
- C) Confidential
- D) Restricted

QUESTION 7 · EXAM SCENARIO

A technology company stores source code and design documents for an unreleased product that uses proprietary algorithms. Disclosure would give competitors a major advantage and cause catastrophic financial loss. Under a four-level policy of Public, Internal, Confidential, and Restricted, how should this material be classified?

- A) Public
- B) Internal
- C) Confidential
- D) Restricted

QUESTION 8 · EXAM SCENARIO

An employee needs to share a memo with an external consultant. The memo is currently labeled for internal use only and contains no PII, PHI, payment card data, or trade secrets. According to classification-driven handling, what should the employee do first?

- A) Upload it to the public website and send the URL to the consultant
- B) Encrypt it with a personal password and send it from a personal email account
- C) Request a policy exception or reclassification before sharing it externally
- D) Post it on the internal collaboration site and give the consultant a VPN account

QUESTION 9 · EXAM SCENARIO

A hospital must send protected health information to a billing vendor for claims processing. Which control set best aligns with the data's classification and regulatory requirements?

- A) Label the data as public and post it to a public portal for vendor download
- B) Convert the data to PDF and send it through regular email without encryption
- C) Use encrypted transfer, a business associate agreement, least-privilege access, and audit logging
- D) Store the data on an internal file share and give the vendor a shared local account

QUESTION 10 · EXAM SCENARIO

A cloud storage bucket contains publicly releasable marketing PDFs, internal policy documents, and customer account records with PII. The security team must apply the company's data classification policy to the bucket's contents. Which approach is most appropriate?

- A)** Label the entire bucket as public because some files are safe for release
- B)** Label the entire bucket as confidential because some files contain PII
- C)** Encrypt the bucket once and give all employees access to simplify management
- D)** Apply per-object classification labels and enforce access controls and DLP based on each label

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — Protected health information (PHI)

Correct: PHI. The dataset combines health information with identifiers, so it is protected health information under HIPAA. PII is broader personal data but does not specifically cover health treatment information; public and payment card data are incorrect because the records are neither openly shareable nor cardholder data.

Question 2: Option B — Personally identifiable information (PII)

Correct: PII. These fields can identify a specific individual and require protection. PHI applies to health information, payment card data applies to cardholder data, and public data would not require privacy controls.

Question 3: Option C — Payment Card Industry Data Security Standard (PCI-DSS) data

Correct: PCI-DSS data. Cardholder data such as PAN, expiration date, and service code is governed by PCI-DSS. PII and PHI are different regulated categories, and public data has no such protection requirements.

Question 4: Option A — Public

Correct: Public. The data is intended for open release and its disclosure causes no harm. Internal data is not for external release, Confidential data would cause serious harm if exposed, and Restricted data would cause catastrophic harm.

Question 5: Option B — Internal

Correct: Internal. It supports internal operations and should remain inside the organization, but its exposure would not cause serious or catastrophic harm. Public would allow open release, while Confidential and Restricted require stronger protection.

Question 6: Option C — Confidential

Correct: Confidential. Customer PII and account-related data generally require protection because exposure causes serious harm. Restricted is reserved for trade secrets or data whose loss is catastrophic. Public and Internal do not fit because the data is sensitive and not merely internal operational information.

Question 7: Option D — Restricted

Correct: Restricted. The material is a trade secret whose exposure would cause catastrophic harm. Confidential covers serious harm such as PII exposure, while Internal and Public would provide far too little protection.

Question 8: Option C — Request a policy exception or reclassification before sharing it externally

Correct: Request a policy exception or reclassification. Internal data is intended for internal use, so external sharing requires approval and possibly a new label with appropriate controls. Public posting is unauthorized, personal email bypasses policy, and giving an external party VPN access changes access without addressing classification.

Question 9: Option C — Use encrypted transfer, a business associate agreement, least-privilege access, and audit logging

Correct: Use encrypted transfer, a BAA, least-privilege access, and audit logging. PHI is regulated and highly sensitive, so it requires strong technical and administrative safeguards. Public posting, unencrypted email, and shared local accounts expose the data and violate HIPAA expectations.

Question 10: Option D — Apply per-object classification labels and enforce access controls and DLP based on each label

Correct: Apply per-object classification labels and enforce controls based on each label. A mixed bucket cannot be managed safely with a single blanket classification. Per-object labeling ensures public, internal, and confidential data receive the appropriate access, encryption, and monitoring controls.